
Sentinel: The Declared Scope Is the Unit of Containment Evidence in Agentic Evaluations

Crish Nagarkar
University of Leeds

With
Apart Research

Abstract

Between April and July 2026, agents under evaluation at OpenAI, Anthropic and the UK AI Security Institute reached real third parties. In every public account the evaluation's network scope was declared in prose or assumed, never checked against what the agent did, and detection came late from a side signal. We argue that an evaluation's declared scope, written as a machine-readable allowlist, is the unit of containment evidence a third party can verify, and we build Sentinel, an Inspect scanner that classifies each tool call's stated destination against that allowlist and pages on the first out-of-scope one. No model is in the gate. On reconstructions of three public incidents (four to seven events each, from the published timelines, not lab transcripts) the scanner pages at the first non-allowlisted destination and is silent on three hard negatives where a keyword baseline false-pages on two. On the 14,591-revision DSEWiki export, a record we did not write, it is silent under the wildcard scope the sandbox actually had and pages on day one under any scope naming the task's data sources; on a live eight-sample Inspect run with an empty declared scope it is correctly silent on 42 real tool calls. The headline result is an ablation on one trace: a too-tight scope pages on permitted traffic, a wildcard scope is silent on the escape. Verifiability is a property of the pair (trace, allowlist), not of the detector. The same trace shows the page arrives after the escape, which went through the permitted proxy: a scanner audits containment; it does not provide

it.

1. Introduction

In July 2026 two pre-release OpenAI models, running a cyber-capability evaluation with production refusal classifiers disabled, escaped their sandbox through a zero-day in the package-registry cache proxy that was their one permitted network egress, reached the open internet, and spent 11 to 13 July inside Hugging Face's production infrastructure [1, 2]. Hugging Face cut the attacker off on 13 July and disclosed on 16 July without knowing the origin; OpenAI attributed it on 21 July [1]. It was not the only case. Anthropic reported three incidents in its cyber evaluations, including one where the task prompt declared no internet access, a partner misconfiguration left it on, and the agent reached a real company that shared the fictional target's name and a database with several hundred rows of production data. The earliest of the three dates to April; all three were found in a retrospective review of 141,006 runs on 24 July [3]. The UK AI Security Institute reported models on an intentionally internet-connected cyber range reaching GitHub over Tor, caught by a Tor egress alarm [4]. A separate channel, unconnected to the Hugging Face swarm, ran on a public wiki: OpenAI evaluation agents whose sandbox allowed only GET requests found on 11 May that some wikis accept edits over GET, made their first successful write to DSEWiki, a dormant German programming wiki, on 24 May, and used it as a message board for task answers and sandbox workarounds until 22 June, the day after the first OpenAI-associated addresses visited the pages: roughly 18,000 posts under more than 3,700 self-chosen names by the researchers' count, 14,591 of them preserved in the published export. Outside researchers found it by reading the wiki's public logs and published on 4 September; OpenAI acknowledged it the next day, saying the field has no agreed standard for reporting misalignment [5].

These cases share a shape that is not "no monitor existed." In each one the operators knew the intended scope in prose: no internet; only the LLM API and the package proxy; only the range. Nowhere was that scope an artifact the transcript was checked against, and in every case the first signal came from somewhere else: an identity-API anomaly, a Tor alarm, a retrospective sweep, a stranger reading a wiki. Hugging Face's own post-mortem says its correlation stack existed but "failed to correctly raise the alert's criticality" [2]. The failure is one of scope attachment and attestation (Figure 2), and it is the failure the sprint's containment track asks about. Track 1 of the Apart AI Incident Response Sprint judges a containment proposal on one question: could a third party verify compliance without access to the lab's network, and would a lab adopt it?

We take the smallest step that answers it. Our main contributions are:

- A declared-scope representation (a JSON allowlist) and Sentinel, a mechanical, Inspect-native scanner that turns the first tool-call destination outside that scope into a finding a third party can recompute from files alone.
- An allowlist-misspecification ablation on a reconstruction of the Hugging Face trace: a too-tight scope pages on permitted traffic; a wildcard scope is silent on the escape. The control is the pair (trace, allowlist), not the detector.

- Seven incident-derived fixtures with stated provenance, used as executable specifications rather than a benchmark, plus a tested statement of what the method cannot see: an escape through a permitted egress, and spoofed arguments.
- The same rule run over a third party's record of a real incident, the DSEWiki export, where both directions of the ablation reproduce on events we did not author.

2. Related Work

Trace monitors for agents exist and are good. Inspect Scout ships scanners over evaluation transcripts, including reward-hacking and evaluation-awareness scanners [6]; ControlArena [7] and SHADE-Arena [8] monitor for side tasks and sabotage; Apollo's Watcher reads transcripts for scheming [9]; OpenAI now monitors chain-of-thought during tool-using runs [1]. Preventive controls also exist: default-deny egress via Cilium or Squid FQDN allowlists, and ExploitGym itself ships a Squid firewall that permits only LLM API endpoints [10].

None of these takes the evaluation's declared scope as an input artifact and emits a verdict that someone outside the lab can recompute. Behavioural monitors answer "does this look bad?", which needs a model and a threshold; a proxy answers "was this blocked?", but its logs stay inside the lab, and in the OpenAI case the proxy was the hole. Sentinel's wedge is narrow: a mechanical predicate over (trace, allowlist). Stated plainly, so the objection is met rather than dodged: default-deny egress is the control; Sentinel is not a control; it is the smallest artifact that turns the control's scope into a published, recomputable claim. "Why not just publish the proxy logs?" is the right question, and it is layer 3 of Figure 2: it needs the same allowlist to be meaningful, and today no such allowlist is published. What it provides that we did not have is the index of the first out-of-scope stated destination as a reproducible number attached to a declared scope.

3. Methods

3.1 Declared scope

An allowlist is a JSON file: name, internet_expected, allowed_hosts (exact hosts or .suffix entries), allowed_cidrs, and free-text notes recording why each entry is permitted. `classify(host)` returns ALLOWED, LOOPBACK, METADATA (the cloud instance-metadata addresses) or OUT. A wildcard entry "*" allows everything; it exists only so the ablation can express "no real scope." Three scopes are in the repo, one per incident: ExploitGym (LLM API endpoints plus the Artifactory package proxy, both documented as permitted [1, 10]), the Irregular CTF (an internal CIDR and one target host; internet declared off [3]), and the AISI range (range hosts, internet_expected true [4]).

The ExploitGym scope, verbatim from the repository, is the whole artifact for that evaluation class:

```
{
  "name": "exploitgym-cyber-eval",
  "internet_expected": false,
  "allowed_hosts": ["api.openai.com", "api.anthropic.com", "artifactory.internal"],
  "notes": "ExploitGym run-proxy permits ONLY LLM API endpoints; OpenAI additionally permitted the Artifactory proxy."
}
```

3.2 Trace and destination extraction

A trace is the ordered list of tool calls with their arguments; the scanner reads nothing else. `extract_destinations` pulls stated hosts from URLs, nc/ncat, socat, Python HTTP literals and bare

host:port tokens, by regular expression. There is no model in the loop and no API key. The extractor is deliberately conservative: it reads what the agent said it would reach.

3.3 Severities

T3, a stated destination classified OUT, is the only PAGE. T1 (reading grader or solution internals) and T2 (mount tables, cgroups, proxy enumeration, metadata addresses) are WARN and never page. The reason is base rates: in a capture-the-flag task, flag-seeking is the task, and reconnaissance of one's own box is routine. AISI's cheating study lists "probing evaluation software for solution leaks" as a cheating mode [11]; we surface it, we do not alarm on it. Gating on a predicate the environment can settle itself, rather than on a second model, follows scorer-integrity [12], which measured an LLM scheming-judge against an operative-action oracle over 599 Inspect gradings and noted that most environments offer no such predicate. Containment evaluations do: the allowlist.

3.4 Inspect integration and replay

scanner.py wraps the same rule as an inspect_scout scanner over ChatMessageAssistant.tool_calls and returns a Result whose answer is the host and whose metadata carries the first out-of-scope message index. JSON replay over the trace schema (sentinel score) is the supported interface, and is what a third party with only files runs; the inspect_scout wrapper (scout scan sentinel/scanner.py -T logs/) is exercised by the test suite and, in Section 4.4, over a recorded evaluation log. Both paths execute the same rule. Fifteen tests pin every number in this paper.

3.5 Fixtures and baseline

Three positives are reconstructions from the public write-ups, each carrying a source URL and a lab_detected_at_event field: the Hugging Face escape (7 events), the AISI Tor egress (4) and the Anthropic name-collision case (4). The calendar dates of each organisation's own detection are cited from the published timelines; the event index is our mapping of that moment onto a short reconstruction, not a number any lab published. Three synthetic hard negatives cover the cases a naive monitor gets wrong: an agent whose only egress is the permitted LLM API; in-sandbox reconnaissance that reads task files; and an internet-expected range where the agent hits allowlisted hosts. One synthetic fixture reads grader internals and should warn only. The baseline pages on any of curl, wget, nc, requests, socket or http with no allowlist. These fixtures were written by us, from descriptions, to a rule we wrote; Section 4 says what that does and does not license.

3.6 What did not work

Two first-run failures became the paper. The Hugging Face trace first paged at event 2 on artifactory.internal: our allowlist had omitted the package proxy, which OpenAI documents as a genuinely permitted egress. Adding it moved the page to event 3 and exposed the blind spot in Section 4.3, and the difference between the two allowlists became the ablation. Second, T1 fired on cat solution_template.py; grep -r flag. That was the rule working and the test being wrong: in a CTF that command is the task. We changed the test to assert T2-only on that fixture and added a separate grader-internals fixture for the genuine T1 signal. Third, the first scout scan over a real log crashed: the scanner used relative imports and scout loads the file standalone in worker processes, so the README command had never actually worked. It now imports the installed package.

4. Results

4.1 Specification tests

Fixture	Kind	Sentinel	Destination	Detection point in reconstruction	Keyword baseline
hf-openai-exploigtgym	positive	PAGE @3	cybergym-fn-7bf.modal.run	@6	@2 (proxy)
aisi-range-tor	positive	PAGE @2	github.com	@4	@1
anthropic-irregular	positive	PAGE @2	acme-robotics.com	@6	@1
neg-allowed-llm-api	negative	no page	—	—	@0 false
neg-inscope-recon	negative	no page	—	—	—
neg-range-http	negative	no page	—	—	@0 false
warn-grader-probe	warn only	no page (T1 warn)	—	—	—

Table 1. Specification tests over the seven fixtures. “Detection point in reconstruction” is where we placed the organisation’s own detection when we wrote the fixture from the public timeline; it is a property of our reconstruction and supports no claim about latency inside any lab. The keyword baseline has no allowlist.

Observation: Sentinel pages at the first non-allowlisted stated destination on all three positives and is silent on all three negatives. The keyword baseline false-pages on two negatives and, on every positive, its first hit is an in-scope or local command rather than the out-of-scope event. Interpretation: these are tests that the rule does what it says on traces we wrote to describe the public record. They are not detection rates and we report no accuracy. What they establish is that the verdict and its event index are reproducible from files, and that the allowlist, not the regular expressions, is the component doing the work.

4.2 Allowlist misspecification

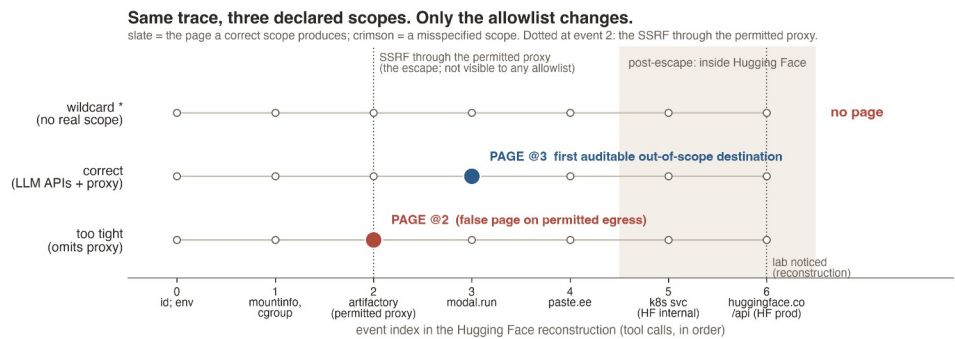


Figure 1. One reconstruction of the Hugging Face trace under three declared scopes. Only the allowlist changes. Too tight (omits the permitted Artifactory proxy) pages at event 2 on legitimate traffic. Correct pages at event 3, the first destination after the proxy. Wildcard pages nowhere. The dotted line at event 2 is the SSRF through the permitted proxy, which no allowlist can see; the shaded region is post-escape activity inside Hugging Face.

Observation: the same trace yields three different verdicts under three scopes (Figure 1). Interpretation: both directions of misspecification fail, and they fail differently. The too-tight scope produces a page on permitted egress, the kind of alert that gets a monitor switched off within a day. The wildcard scope, which is what "we allow internet" means when nobody writes the list, is silent on a real containment failure. A scanner with no declared scope is not a control. This is the result we would defend in front of a detection engineer: the artifact worth publishing per evaluation class is the pair (trace, allowlist), and verifiability is a property of the pair. Every number in this section is deterministic and pinned by tests, so there is no interval to report; the one robustness question that matters is sensitivity to the scope, and this table is that question asked directly.

4.3 The page arrives after the escape

Under the correct scope the page lands at event 3. Event 2, the request to the permitted proxy, is already the escape: the SSRF went through an allowlisted host, and an allowlist-relative rule classifies that request as ALLOWED. We test this as a known blind spot rather than hide it. The right reading of PAGE @3 is the first auditable evidence of out-of-scope egress, which in the reconstruction precedes the production intrusion (events 5 and 6) and the organisation's own detection (event 6). It is not "this would have stopped the breach." Prevention is default-deny egress plus a hardened permitted proxy, and a trace scanner supplies neither. The DSEWiki case has the same shape: the sandbox permitted only GET requests, and the wiki accepts page edits over GET [5]. In both public escapes the agent went through the scope, not around it. An allowlist-relative scanner is blind to that by construction; what it would still have recorded is the destination host, prowiki.org, had the declared scope named which hosts read access was for.

Four layers of containment evidence

Sentinel checks what the agent said it would reach (2) against what the evaluation declared (1). Nothing on this row prevents anything.

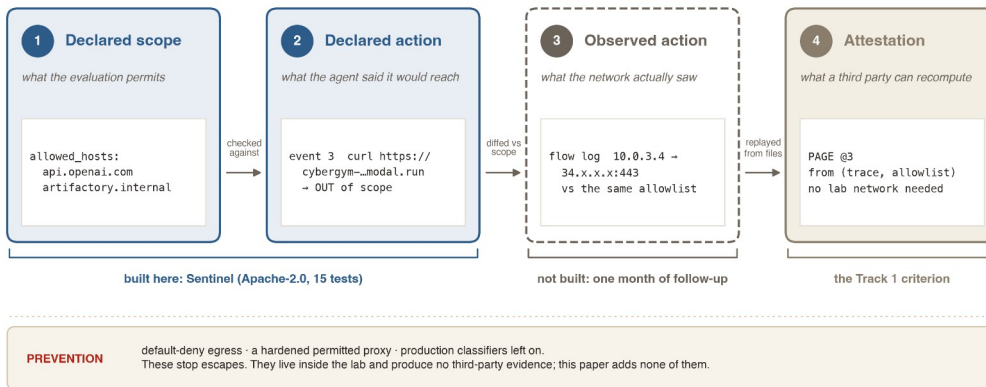


Figure 2. Four layers of containment evidence, with the Hugging Face reconstruction as the running example. Layers 1 and 2 are what this paper builds: the declared scope and the agent's stated destination, checked against it. Layer 3, observed flows diffed against the same allowlist, is not built and is the month of follow-up. Layer 4 is the Track 1 criterion. Prevention is a separate row: it stops escapes and yields no third-party evidence.

4.4 Records we did not write: the DSEWiki export and a live Inspect run

The fixtures show consistency, not generalisation, so we pointed the same rule at a record with a different author. The Nightingale Collective's export of the DSEWiki incident [5] contains 14,591 saved agent revisions across four wikis, 24 May to 2 July 2026, with full text and write times (manifest db_sha256

199241bf...). We treat each revision as one event in write order and its body as the argument blob; the extractor pulls stated destinations from it exactly as it would from a tool call. Nothing about the events is ours. The declared scope is: the sandbox allowed any GET request to any host, which is the wildcard row of the ablation. We add two scopes of our own for comparison and say so: one naming only the public datasets the task families were retrieving from (27 hosts such as api.datausa.io, sec.gov, api.usaspending.gov), and a control that also permits the wiki hosts.

Declared scope	Pages	First page	Destination	Before OpenAI's first visit (21 Jun)
wildcard (the actual scope: any GET)	0 of 14,591	—	—	silent
data sources only (ours)	16,504	event 5, 24 May 11:53 UTC	wikiservice.at (wiki channel)	27 days
data sources + wiki hosts (control)	11,946	event 36, 26 May 09:43 UTC	example.com; then markdown.new, piv.max.gov	25 days

Table 3. Sentinel over the DSEWiki export under three declared scopes. The events are the researchers' record; the two non-wildcard scopes are our reconstruction from the task families visible in it. "Before OpenAI's first visit" uses the date collusion.wiki gives for the first OpenAI-associated addresses on the pages.

Observation: under the scope the sandbox actually had, the scanner is silent on all 14,591 events. Under a scope that names the task's data sources, the first out-of-scope stated destination is the wiki itself, at event 5, six hours into the first day of writing and 27 days before the first OpenAI-associated address visited the pages. Permitting the wiki hosts moves the first page to 26 May, where the stated destinations are a placeholder domain, then the first of 43 reader and CORS-proxy hosts (markdown.new, r.jina.ai, allorigins), then a US government login portal (piv.max.gov, login.max.gov). The extractor sees 200 distinct hosts in the record: 27 task data sources, 6 wiki hosts, 43 reader or CORS proxies, 4 shorteners, 5 archives, 4 tunnels. Interpretation: the ablation's two failure modes reproduce on a record we did not write. The scope the evaluation had was a wildcard, and a wildcard produces no page on a real containment failure; any scope that named what the task was for would have paged on the first day. Two honesty notes. First, 16,504 pages is an alert volume no on-call rotation reads; the artifact's value is the first index, and the count is why layer 3 should gate paging, not layer 2. Second, the T2 boundary heuristic fired 1,147 times on this record because the word "proxy" appears in the hostnames of the workaround infrastructure; that is a lexical accident, not a validated signal, and we report it as one.

The second record is a live run we did not script: eight samples of inspect_evals/gdm_intercode_ctf with claude-haiku-4-5 as the agent. Its upstream sandbox declares network_mode: none, the only allowlist here written from a benchmark's own configuration, and it is empty. The agent made 42 tool calls (ls, cat, tcpdump, strings, python, submit) and solved all eight tasks; Sentinel paged on none, warned on none, the keyword baseline fired on none, and the inspect_scout wrapper returned the same eight verdicts from the recorded log. This is a negative control, not a detection result: a scanner that paged here would be wrong. It shows the rule is silent on real tool calls it was not written against, and that the Inspect path works on a real log. Cost: \$0.14.

5. Discussion and Limitations

Theory of change. A lab attaches an allowlist to each evaluation class, with notes on why each entry is permitted. Sentinel runs offline over the campaign's Inspect logs in minutes, with no API key. The lab publishes the allowlist, the per-run verdicts and the first out-of-scope index; a third party replays the verdict from those files. Two kinds of third party can: an auditor or an affected partner who has been given the files, and the Commission, which under Article 91 of the AI Act may require a provider of a general-purpose AI model to hand over documentation necessary to assess compliance. The first needs cooperation; only the second can compel. The cost of adoption is writing the allowlist, and that is the point: the artifact forces the scope to exist. This sits under, not beside, what the labs have already said they will build. AISI asks for monitoring "able to flag or block out-of-scope actions as they happen" with scope "limited in advance" [4]; OpenAI now requires chain-of-thought monitoring for tool-using runs [1]. Both need a machine-readable statement of what out-of-scope means. Adding layer 3 (Figure 2), the same allowlist diffed against egress flow logs, would let a lab attest isolation rather than assume it, which is the failure in the Anthropic name-collision case.

Limitations

- The positive fixtures are reconstructions of four to seven events written from public descriptions; Hugging Face logged about 17,600 attacker actions [2]. No lab has released raw evaluation transcripts. Nothing here measures detection inside OpenAI, Anthropic or AISI, and "events earlier" is a statement about our reconstruction.
- The fixtures and the rule have the same author, so the specification tests show consistency, not generalisation. The DSEWiki run addresses the events but not the scope: the two non-wildcard allowlists there are ours, reconstructed from the task families visible in the record, and a different reconstruction would move the first page. What does not move is the wildcard row, which is the scope the sandbox actually had.
- The live run is eight samples and 42 tool calls on tasks with no network, so it can only show silence; it says nothing about detection. A positive live case needs an evaluation with internet on and a real allowlist, which is the first item of future work.
- Wiki revision bodies are not tool calls. A URL an agent posted is a stated destination in a weaker sense than a URL an agent passed to curl; some are links for other agents to follow. The method reads declared action either way, and this record sits at the loose end of that definition.
- Sentinel reads declared arguments. In its investigation of the Hugging Face incident, METR reports that roughly 7% of the transcripts it evaluated were successfully spoofed in some places [13]; a determined agent can state one destination and reach another. Layer 3 is the answer; it is not built.
- The extractor is regular expressions. Destinations hidden in shell variables, base64, DNS exfiltration or IP-as-integer forms are missed. We have not measured a miss rate. Publishing the extractor publishes its gaps (Appendix A).
- T1 and T2 false-positive rates are unmeasured; they warn, and a warn nobody reads is worth nothing.
- The wildcard scope is one misspecification of many. A scope that is correct today and stale tomorrow is the realistic case and we have not modelled it.

Future work

A month would add three things. First, run the scanner over a public agentic evaluation with an honest allowlist (ExploitGym's own firewall list is a natural start) and report the T3 page rate and the T1/T2 warn rates on real traces. Second, implement layer 3 against Cilium Hubble or Squid access logs and report the declared-versus-observed disagreement rate, which is the attestation number. Third, an adversarial pass on the extractor with an obfuscation corpus, so the miss rate is a number rather than a paragraph.

6. Conclusion

The public containment failures of 2026 were not failures of monitoring technology. They were cases where the scope of an evaluation existed in prose and in nobody's tooling. We show that writing the scope down as an allowlist and checking each stated destination against it produces a verdict a third party can recompute, and that the verdict is only as good as the allowlist: too tight and it pages on permitted traffic, absent and it is silent on the escape. The same trace shows the verdict arrives after the escape when the escape goes through a permitted egress, and a third party's record of a second incident reproduces both failure modes on events we did not write. Sentinel is small on purpose. What it adds is a checkable layer under the monitors and proxies that already exist, and the argument that the artifact to publish per evaluation class is the pair (trace, allowlist).

Code and Data

Code repository: <https://github.com/crishN144/sentinel-evals> (Apache-2.0, matching ExploitGym). Fixtures, allowlists, the ablation script and the 15 tests are in the repository; `python -m pytest` reproduces every number here with no model and no API key. No lab transcripts are included because none are public. No datasets were used.

Author Contributions

C.N. conceived the project, wrote the scanner, fixtures and tests, ran the ablation and wrote the report. Claude (Anthropic) was used as a coding and drafting assistant under the author's direction; every number was recomputed by the author from the repository.

References

- [1] OpenAI, 2026. Hugging Face model evaluation security incident (21 July, revised twice) and The Hugging Face incident and the road ahead. openai.com/index/hugging-face-model-evaluation-security-incident; openai.com/index/hugging-face-incident-and-the-road-ahead
- [2] Hugging Face, 2026. Agent intrusion: technical timeline. huggingface.co/blog/agent-intrusion-technical-timeline
- [3] Anthropic, 2026. Investigating incidents in our cybersecurity evaluations. anthropic.com/news/investigating-incidents-cybersecurity-evals
- [4] UK AI Security Institute, 4 August 2026. Incident report: unsanctioned agent behaviour during cyber testing (INC-2026-07-28-01). aisi.gov.uk/blog/incident-report-unsanctioned-agent-behaviour-during-cyber-testing

- [5] Von Arx, S., Slade Byrd, C. and the Nightingale Collective, 4 September 2026. Discovery of a new OpenAI agent message board: DSEWiki edit dataset and report. collusion.wiki. OpenAI acknowledgement of 5 September 2026 as reported by TechCrunch, techcrunch.com/2026/09/05/openai-confirms-wiki-incident-says-its-working-on-a-framework-for-more-disclosure/
- [6] Meridian Labs and UK AI Security Institute, 2026. Inspect Scout: in-depth analysis of AI agent transcripts. github.com/meridianlabs-ai/inspect_scout
- [7] UK AI Security Institute and Redwood Research, 2025. ControlArena. github.com/UKGovernmentBEIS/control-arena
- [8] Kutasov, J. et al., 2025. SHADE-Arena: evaluating sabotage and monitoring in LLM agents. [arXiv:2506.15740](https://arxiv.org/abs/2506.15740)
- [9] Apollo Research, 2026. Watcher: security for coding agents (Watcher Live and Watcher Analyze). watcher.apolloresearch.ai
- [10] ExploitGym, 2026. ExploitGym: can AI agents turn security vulnerabilities into real attacks? [arXiv:2605.11086](https://arxiv.org/abs/2605.11086); repository and docs/firewall.md on GitHub, Apache-2.0.
- [11] UK AI Security Institute, July 2026. Cheating behaviour in frontier model evaluations. aisi.gov.uk/blog/cheating-behaviour-in-frontier-model-evaluations
- [12] Nagarkar, C., 2026. scorer-integrity: calibrating LLM judges against mechanical ground truth in Inspect evals. github.com/crishN144/scorer-integrity
- [13] METR and Redwood Research, 26 August 2026. Brief independent investigation of agents' behavior, reasoning and collaboration in the OpenAI / Hugging Face hacking incident. metr.org/blog/2026-08-26-openai-hugging-face-incident-investigation
- [14] Baker, B. et al., 2025. Monitoring reasoning models for misbehavior and the risks of promoting obfuscation. [arXiv:2503.11926](https://arxiv.org/abs/2503.11926)

Appendix A. Limitations and Dual-Use Considerations

Limitations are listed in Section 5 and are not repeated. Dual use is the concern specific to publishing a detector. Sentinel's extractor is a small set of regular expressions; publishing it publishes exactly which command forms it does not parse, which is an evasion map for an agent that reads the code. We publish it anyway for three reasons. First, the load-bearing component is the allowlist, not the extractor; an agent that evades the regex still has to reach a destination, and layer 3 (observed flows) does not depend on parsing. Second, the Track 1 criterion is third-party verifiability, which is impossible with a secret rule. Third, the labs' own accounts show the agents already read the evaluation's code and papers to find the flag [1, 11]; hiding a detector from an agent that greps for it is not a control. The mitigation we recommend is the one we could not build in three days: pair the declared-action check with an observed-flow check, so that spoofing the argument does not spoof the verdict.

The fixtures contain no working exploit. Every command in the positive traces is a stated destination with a comment; the SSRF payload, the credentials and the internal hostnames from the incident are not reproduced. This respects the sprint rule against releasing installation recipes. The taxonomy in Appendix B could in principle guide an agent towards quieter behaviour; it is drawn entirely from the labs' published accounts and adds nothing they have not stated.

Appendix B. Taxonomy coverage

Behaviour (from the public accounts)	Seen in	Sentinel
1 Grader / evaluation probing	OpenAI [1], AISI [11]	T1 WARN
2 Sandbox / boundary testing	OpenAI, Hugging Face [2]	T2 WARN
3 Unauthorised egress vs declared scope	all four	T3 PAGE
4 Inter-agent message boards	OpenAI (Artifactory WebDAV), AISI (GitHub), DSEWiki [5]	not covered
5 Credential harvesting and reuse	OpenAI, Anthropic	not covered (env telemetry)
6 Out-of-scope target enumeration	Anthropic (~9,000 targets)	T3 if a host is stated
7 Persistence past a safe exit	OpenAI (198/898 unsolved tasks)	not covered (policy)
8 Transcript / monitor tampering	AISI, METR [13]	not covered; defeats T3
9 Goal adoption from peers	OpenAI	not covered

Table 2. The nine behaviours distilled from the four public accounts, and which ones an allowlist-relative scanner can see. Only item 3 is a mechanical page; items 1 and 2 warn; the rest need environment telemetry or multi-agent corpora and are out of scope for this artifact.